

Web Attack Risk Prediction

ML ve XAI ile Web Saldırı Tespiti
KVKK Bazlı Maliyet/Fayda Analizi ve ALE Projeksiyon

YÖNETİCİ ÖZETİ RAPORU

Metrik	Değer
Toplam Veri	61.065 HTTP request (4 farklı kaynak)
Karşılaştırılan Model	Random Forest, XGBoost, LightGBM (GridSearchCV)
En İyi Model	XGBoost (F1=0.9321, AUC=0.9919)
FN Maliyeti	43.677 TL (Beklenen Değer: 8.7M TL × %0.5)
Optimal Threshold	0.05 (maliyet minimizasyonu)
Threshold Tasarrufu	11.055.885 TL (test seti)
ALE Tasarruf (Orta)	43.6M TL/yıl (olay bazlı, 5 olay/yıl)
Inference Latency	1.04 ms/request — Near real-time IDS uygun

1. Problem Tanımı

Web uygulamalarına yönelik siber saldırılar işletmeler için ciddi finansal ve yasal riskler taşır. KVKK kapsamında veri güvenliği ihlalleri 2025 itibarıyla 13.620.402 TL'ye kadar idari para cezası ile sonuçlanabilir. Bu projede 61.065 HTTP request analiz edilerek ML tabanlı saldırı tespit sistemi geliştirilmiş, işletme değeri ALE metodolojisiyle kanıtlanmıştır.

2. Veri Kaynakları ve Harmanlama

4 farklı veri kaynağı anlamlı şekilde birleştirilmiştir:

Kaynak	Tür	Boyut	Harmanlama Rolü
CSIC 2010	Kaggle CSV	61.065	Ana veri seti: HTTP request'leri
Web App Payloads	Kaggle JSONL	455	Saldırı imzaları → regex pattern
Foospidy Payloads	GitHub	28.569	Kapsamlı saldırı pattern koleksiyonu
Türkiye KVKK	Sentetik	250	KVKK cezaları + ALE maliyet mapping

3. Feature Engineering (12 Yeni Özellik)

- request_length, url_length, content_length — Request boyut metrikleri
- special_char_count, digit_count — Saldırı syntax göstergeleri
- entropy_score (Shannon Entropy) — Obfuscated payload tespiti
- encoded_char_ratio — WAF bypass tespiti
- uppercase_ratio — Encoding manipülasyonu
- parameter_count, url_depth, is_post, is_put — Yapısal HTTP özellikleri

4. Modelleme (3 Model, GridSearchCV)

3 model GridSearchCV ile optimize edilmiş, 5-fold Stratified CV ile değerlendirilmiştir:

Model	Accuracy	F1 Score	Precision	AUC-ROC
Random Forest	0.9390	0.9275	0.90	0.9913
XGBoost	0.9433	0.9321	0.91	0.9919
LightGBM	0.9390	0.9270	0.91	0.9913

5. Açıklanabilir Yapay Zeka (SHAP — XGBoost)

Model kararları SHAP ile hem global hem bireysel düzeyde açıklanmıştır.

Global Bulgular:

- entropy_score ve encoded_char_ratio en yüksek SHAP etkisine sahip
- Yüksek entropy → saldırı olasılığı artıyor (obfuscation tespiti)
- uppercase_ratio ve parameter_count kritik ayrıştırıcılar

Bireysel Tahmin (Local Explanation):

- special_char_count: 5.0 → SHAP: +1.1160 (↑ Saldırı)
- digit_count: 10.0 → SHAP: +0.9471 (↑ Saldırı)
- entropy_score: 4.90 → SHAP: +0.4982 (↑ Saldırı)
- uppercase_ratio: 0.049 → SHAP: -0.4119 (↓ Normal)

6. KVKK Bazlı Maliyet/Fayda Simülasyonu

6.1 Maliyet Matrisi

Senaryo	Maliyet	Türetim Yöntemi
False Positive	150 TL	Normal kullanıcı bloklanması + destek maliyeti
False Negative	43.677 TL	Ort. olay maliyeti (8.735.389 TL) × ihlale dönüşme olas. (%0.5)
True Positive	0 TL	Mükerrer hesaplama önleni; tasarruf = önlenen zarar

6.2 Threshold Optimizasyonu

- Default threshold (0.50): 11.464.347 TL
- Optimal threshold (0.05): 408.462 TL
- Threshold tasarrufu: 11.055.885 TL

6.3 Yıllık Projeksiyon (ALE — Olay Bazlı)

Request bazlı değil, olay bazlı hesaplama. Her olay = bir saldırı kampanyası (binlerce request içerebilir).
Model recall: %99.9

Senaryo	Yıllık Olay	Model Yok	ML Model	Tasarruf
Küçük İşletme	2	17.4M TL	22.9K TL	17.4M TL
Orta E-Ticaret	5	43.6M TL	57.2K TL	43.6M TL
Büyük Fintech	12	104.8M TL	137.4K TL	104.6M TL

Metodoloji: NIST SP 800-30 Risk Assessment Framework. KVKK veritabanı sentetik olup gerçek kurum verileri değildir.

7. Model Inference Performansı

Metrik	Değer	Değerlendirme
Ort. Latency	1.04 ms/request	Near real-time uygun
P99 Latency	1.54 ms/request	SLA uyumlu
Throughput	962 request/saniye	Asenkron IDS yeterli

Mimari: Yoğun trafikte inline değil, asenkron IDS katmanı önerilir (WAF → Kafka → ML Model → Dinamik WAF kural güncellemesi).

8. Sonuç ve Öneriler

Yapılanlar:

- 4 farklı veri kaynağı başarıyla harmanlanmıştır
- 12 iş mantığına dayalı feature türetilmiş, data leakage önlenmiştir
- 3 model (RF, XGBoost, LightGBM) GridSearchCV ile optimize edilmiştir
- XGBoost: %94.33 accuracy, F1=0.9321, AUC-ROC=0.9919
- FN maliyeti KVKK veritabanından Beklenen Değer yöntemiyle türetilmiştir
- TP=0 ile mükerrer hesaplama önlenmiştir
- ALE bazlı olay bazlı yıllık projeksiyon: Orta ölçekte 43.6M TL/yıl tasarruf
- SHAP ile XGBoost kararları global ve local düzeyde açıklanmıştır
- Inference benchmark: 1.04 ms — asenkron IDS mimarisi önerilmiştir

Öneriler:

- Threshold=0.05 ile asenkron IDS olarak deploy edilmesi önerilir
- WAF logları Kafka/RabbitMQ kuyruğuna beslenerek near real-time risk skorlaması
- KVKK uyum sürecinde ML tabanlı IDS “veri güvenliği yükümlülüğü” olarak gösterilebilir
- Periyodik payload veritabanı güncellemesi ile concept drift yönetimi

GitHub Repository: https://github.com/MuhammedAsef/web_attack_risk_prediction

YBS 4. Sınıf — Python ile Veri Bilimi Dönem Sonu Projesi

Kaynaklar: KVKK Madde 18 (2025), IBM Cost of Data Breach 2024, OWASP Top 10 2021, NIST SP 800-30